

Homework 08: Digital Signature Verification

Nicolas Leone
Student ID: 1986354
Cybersecurity

December 17, 2025

Contents

1	Introduction	3
2	Digital Signature Verification Checklist	3
2.1	Signature Integrity	3
2.2	Certificate Validation	3
2.3	Revocation Status	3
2.4	Trust Validation	4
2.5	Timestamp Verification	4
2.6	PAdES-Specific Checks	4
3	Certificate Chain Extraction	4
3.1	Extraction Process	4
3.2	Certificate Chain Analysis	4
3.2.1	Certificate #0 - End Entity (Signer)	5
4	X.509 Certificate Field Analysis	5
4.1	Standard X.509 Fields	5
4.1.1	Version	5
4.1.2	Serial Number	5
4.1.3	Signature Algorithm	5
4.1.4	Issuer	5
4.1.5	Validity Period	6
4.1.6	Subject	6
4.1.7	Subject Public Key Info	6
4.1.8	Extensions (v3)	6
4.2	Field Analysis for test_signed.pdf	6
4.2.1	Basic Certificate Information	6
4.2.2	Issuer and Subject	7
4.2.3	Validity Period	7
4.2.4	Public Key Information	7
4.2.5	X.509v3 Extensions	7

5	CRL Update Interval Analysis	8
5.1	CRL Fields and Update Interval	8
5.2	CRL Retrieval and Analysis	9
5.3	CRL Analysis Results	9
6	OCSP Analysis	10
6.1	OCSP Protocol Overview	10
6.2	OCSP Response Status Values	10
6.3	OCSP Query Using OpenSSL	10
6.4	OCSP Response Analysis	11
6.5	OCSP Query and Execution	11
6.6	OCSP Response Analysis	11
6.7	OCSP vs CRL Comparison	12
7	Results and Findings	12
7.1	Signature Verification Results	12
7.2	Certificate Analysis Summary	13
7.3	Revocation Status Verification	13
7.4	Security Assessment	13
7.4.1	Strengths	13
7.4.2	Considerations	13
7.5	Timeline Analysis	14
7.6	Compliance with Verification Checklist	14
8	Conclusion	15
8.1	Summary of Findings	15
8.2	Key Observations	15
8.2.1	Technical Excellence	15
8.2.2	Legal Standing	16
8.2.3	Revocation Architecture	16
8.3	Tools and Methodology	16
8.4	Final Verdict	16

1 Introduction

This homework focuses on the verification of digital signatures in PAdES (PDF Advanced Electronic Signatures) format. The objective is to analyze a signed PDF document (`test_signed.pdf`) by:

- Drafting a comprehensive checklist for digital signature verification
- Extracting and analyzing the complete certificate chain
- Examining the semantics of X.509 certificate fields
- Determining the CRL (Certificate Revocation List) update interval
- Analyzing the OCSP (Online Certificate Status Protocol) responder output

2 Digital Signature Verification Checklist

A comprehensive verification of a digital signature requires multiple checks to ensure authenticity, integrity, and validity. Below is a detailed checklist:

2.1 Signature Integrity

1. **Signature Validation:** Verify that the digital signature is mathematically correct
2. **Document Integrity:** Confirm that the document has not been modified after signing
3. **Hash Verification:** Validate that the computed hash matches the signed hash

2.2 Certificate Validation

1. **Certificate Chain:** Extract and validate the complete certificate chain up to a trusted root CA
2. **Certificate Validity Period:** Check that the certificate was valid at signing time
3. **Certificate Purpose:** Verify that the certificate has the correct key usage extensions
4. **Certificate Format:** Ensure the certificate is in valid X.509 format

2.3 Revocation Status

1. **CRL Check:** Verify the certificate against the Certificate Revocation List
2. **CRL Validity:** Ensure the CRL is current and not expired
3. **OCSP Check:** Query the OCSP responder for real-time revocation status
4. **OCSP Response Validity:** Verify the OCSP response signature and freshness

2.4 Trust Validation

1. **Root CA Trust:** Verify that the root CA is in the trusted certificate store
2. **Certificate Policies:** Check certificate policy compliance
3. **Name Constraints:** Validate any name constraints in the chain

2.5 Timestamp Verification

1. **Timestamp Presence:** Check if a trusted timestamp is present
2. **Timestamp Validity:** Verify the timestamp signature
3. **Signing Time:** Validate the signing time is within certificate validity

2.6 PAdES-Specific Checks

1. **PAdES Compliance:** Verify conformance to PAdES standards (PAdES-B, PAdES-T, PAdES-LT, PAdES-LTA)
2. **Signature Dictionary:** Validate the PDF signature dictionary
3. **Document Security Store (DSS):** Check for presence and validity of DSS for long-term validation

3 Certificate Chain Extraction

The certificate chain represents the path from the signer's certificate to a trusted root Certificate Authority (CA). Each certificate in the chain is signed by the next certificate, creating a chain of trust.

3.1 Extraction Process

The certificate chain can be extracted using various tools such as OpenSSL, pdfsig, or specialized Python libraries. The following command extracts certificates from a signed PDF:

```
# Using pdfsig (part of poppler-utils)
pdfsig -dump test_signed.pdf

# Using Python with PyPDF2 and cryptography
python3 analyze_signature.py --extract-certs test_signed.pdf
```

Listing 1: Extracting certificates from signed PDF

3.2 Certificate Chain Analysis

The certificate chain extracted from `test_signed.pdf` contains the following certificate:

3.2.1 Certificate #0 - End Entity (Signer)

- **Subject:** C=IT, SN=d'Amore, GN=Fabrizio, serialNumber=TINIT-DMRFRZ60P04H501I, CN=Fabrizio d'Amore, dnQualifier=WSREF-947466...
- **Issuer:** C=IT, L=Arezzo, O=ArubaPEC S.p.A., organizationIdentifier=VATIT-01879020517, OU=Qualified Trust Service Provider, CN=ArubaPEC EU Qualified Certificates CA G1
- **Serial Number:** 60:7e:88:fc:e0:f3:c5:00:7c:11:11:2d:90:20:46:a5
- **Validity Period:** Nov 5 13:24:18 2024 GMT to Nov 5 13:24:18 2027 GMT
- **Public Key:** RSA 2048 bit
- **Signature Algorithm:** sha256WithRSAEncryption

The certificate chain consists of a single end-entity certificate, with the issuer certificate available via the Authority Information Access (AIA) extension. The full chain extends to the ArubaPEC root CA, which is part of the eIDAS qualified trust service providers.

4 X.509 Certificate Field Analysis

X.509 is the standard format for public key certificates. Each certificate contains several fields that provide information about the certificate holder, issuer, validity period, and usage constraints.

4.1 Standard X.509 Fields

4.1.1 Version

Indicates the X.509 certificate version (typically v3 for modern certificates).

4.1.2 Serial Number

A unique identifier assigned by the CA to distinguish certificates.

4.1.3 Signature Algorithm

The cryptographic algorithm used to sign the certificate (e.g., SHA256withRSA, ECDSA).

4.1.4 Issuer

The Distinguished Name (DN) of the Certificate Authority that issued the certificate. Contains fields like:

- C (Country)
- O (Organization)
- OU (Organizational Unit)
- CN (Common Name)

4.1.5 Validity Period

- **Not Before:** The date and time before which the certificate is not valid
- **Not After:** The expiration date and time of the certificate

4.1.6 Subject

The Distinguished Name of the certificate holder (the entity being certified).

4.1.7 Subject Public Key Info

Contains the public key and the algorithm identifier (e.g., RSA, ECDSA).

4.1.8 Extensions (v3)

Additional fields that provide extra information:

- **Key Usage:** Specifies the purpose of the key (e.g., digitalSignature, keyEncipherment)
- **Extended Key Usage:** Further specifies usage (e.g., serverAuth, clientAuth, codeSigning)
- **Subject Alternative Name (SAN):** Alternative identifiers (e.g., additional domain names, email addresses)
- **Authority Key Identifier:** Links to the issuer's public key
- **Subject Key Identifier:** Unique identifier for the subject's public key
- **CRL Distribution Points:** URLs where the CRL can be retrieved
- **Authority Information Access (AIA):** Contains OCSP responder URL and CA issuer URL
- **Certificate Policies:** OIDs defining the policies under which the certificate was issued
- **Basic Constraints:** Indicates if the certificate is a CA certificate and path length constraints

4.2 Field Analysis for test_signed.pdf

4.2.1 Basic Certificate Information

Version: 3 (0x2) - X.509v3 certificate

Serial Number: 60:7e:88:fc:e0:f3:c5:00:7c:11:11:2d:90:20:46:a5

This is a unique identifier assigned by ArubaPEC CA to distinguish this certificate from all others issued by the same CA.

Signature Algorithm: sha256WithRSAEncryption

This indicates that the certificate is signed using SHA-256 hash function combined with RSA encryption, which is currently considered cryptographically secure.

4.2.2 Issuer and Subject

Issuer Distinguished Name:

C=IT, L=Arezzo, O=ArubaPEC S.p.A.,
organizationIdentifier=VATIT-01879020517,
OU=Qualified Trust Service Provider,
CN=ArubaPEC EU Qualified Certificates
CA G1

Subject Distinguished Name:

C=IT, SN=d'Amore, GN=Fabrizio,
serialNumber=TINIT-DMRFRZ60P04H501I,
CN=Fabrizio d'Amore,
dnQualifier=WSREF-947466025428...

The subject contains the Italian tax identification number (Codice Fiscale) in the serialNumber field, which is typical for Italian qualified certificates.

4.2.3 Validity Period

Not Before: Nov 5 13:24:18 2024 GMT

Not After: Nov 5 13:24:18 2027 GMT

Certificate Lifetime: 3 years

The certificate was valid at the signing time (Dec 08 2025 15:49:26) and is currently valid.

4.2.4 Public Key Information

Algorithm: RSA Encryption

Key Size: 2048 bits

Exponent: 65537 (0x10001)

The 2048-bit RSA key provides adequate security for the certificate's lifetime according to current NIST recommendations.

4.2.5 X.509v3 Extensions

Authority Key Identifier:

C6:6F:3B:85:7B:D1:26:B1:
78:9A:42:A4:25:69:0C:F6:
FF:7A:A0:67

Links this certificate to the issuer's public key.

Subject Key Identifier:

25:60:64:8E:3E:5D:07:11:
36:E3:91:34:6C:02:1B:95:
CA:E5:8E:5F

Unique identifier for this certificate's public key.

Key Usage (Critical):

- Non Repudiation

The certificate can only be used for digital signatures where non-repudiation is required. The signer cannot deny having signed a document.

Authority Information Access:

- CA Issuers: <http://cacert.pec.it/certs/arubapec-eidas-g1>
- OCSP: <http://ocsp01.pec.it/va/arubapec-eidas-g1>

CRL Distribution Points:

- URI: <http://crl01.pec.it/va/arubapec-eidas-g1/crl>

Certificate Policies:

- Policy: 0.4.0.194112.1.2
- Policy: 1.3.6.1.4.1.29741.1.7.2
- Policy: 1.3.76.16.6
- CPS: <https://www.pec.it/repository/arubapec-qualif-cps.pdf>

Qualified Certificate Statements:

The certificate includes QC statements indicating compliance with eIDAS Regulation (EU) No 910/2014 for qualified certificates. This provides the certificate with legal standing equivalent to handwritten signatures in the EU.

Issuer Alternative Name:

- email: info@arubapec.it

5 CRL Update Interval Analysis

Certificate Revocation Lists (CRLs) are periodically published lists of revoked certificates. The update interval is crucial for determining how current the revocation information is.

5.1 CRL Fields and Update Interval

A CRL contains two critical timestamp fields that determine the currency of revocation information. The **This Update** field indicates when the CRL was issued, while the **Next Update** field specifies when the next CRL will be published. This determines the maximum staleness of revocation information. The update interval is calculated as:

$$\text{Update Interval} = \text{Next Update} - \text{This Update}$$

5.2 CRL Retrieval and Analysis

The CRL Distribution Point can be extracted from the certificate and used to download the CRL using the following commands:

```
# Extract CRL Distribution Point from certificate
openssl x509 -in cert.pem -noout -text | grep -A 4 "CRL
    Distribution"

# Download CRL
wget -O crl.der <CRL_URL>

# Convert DER to PEM if needed
openssl crl -inform DER -in crl.der -outform PEM -out crl.pem

# Display CRL information
openssl crl -in crl.pem -noout -text
```

Listing 2: Downloading and analyzing CRL

For `test_signed.pdf`, the CRL was successfully downloaded from `http://cr101.pec.it/va/arubapec-eidas-g1/crl` with a size of 2.7 MB (2.0 MB in DER format), indicating an actively managed certificate infrastructure.

5.3 CRL Analysis Results

The downloaded CRL (version 2) is signed using `sha256WithRSAEncryption` by the ArubaPEC EU Qualified Certificates CA G1 (organizationIdentifier=VATIT-01879020517). The CRL analysis revealed the following key information:

Temporal Information:

- Last Update: Dec 16 14:48:13 2025 GMT
- Next Update: Dec 17 14:48:13 2025 GMT
- CRL Number: 82884

Update Interval Calculation:

$$\text{Update Interval} = \text{Dec 17 14:48:13} - \text{Dec 16 14:48:13} = 24 \text{ hours}$$

The CRL is updated daily at 14:48:13 GMT, providing a 24-hour window for revocation information currency. This represents a reasonable balance between freshness of revocation data and system load, and is compliant with eIDAS requirements for qualified certificates.

Certificate Revocation Status: The certificate with serial number `60:7e:88:fc:e0:f3:c5:00:7c:11:11:2d:90:20:46:a5` (Fabrizio d'Amore) is **NOT** present in the revocation list, confirming it has not been revoked.

CRL Extensions: The CRL includes several extensions that provide additional meta-data. The Authority Key Identifier (`C6:6F:3B:85:7B:D1:26:B1:78:9A:42:A4:25:69:0C:F6:FF:7A:A0:67`) links the CRL to the issuing CA's key. The CRL Number (82884) is a sequential identifier for this CRL issue. The Archive Cutoff date (Apr 26, 2017) indicates

that certificates revoked before this date may not appear in the CRL, preventing infinite growth of the revocation list.

The CRL contains numerous revoked certificates with various revocation reasons, including "Superseded" entries where certificates have been replaced with new ones. This active revocation management demonstrates a well-maintained PKI infrastructure.

6 OCSF Analysis

The Online Certificate Status Protocol (OCSF) provides real-time certificate revocation status, offering a more efficient alternative to CRLs.

6.1 OCSF Protocol Overview

OCSF works by:

1. Client sends an OCSF request to the OCSF responder URL (found in the certificate's AIA extension)
2. OCSF responder checks the certificate status
3. Responder sends back a signed response indicating the certificate status

6.2 OCSF Response Status Values

- **Good:** The certificate is valid and not revoked
- **Revoked:** The certificate has been revoked
- **Unknown:** The responder doesn't have information about the certificate

6.3 OCSF Query Using OpenSSL

```
# Extract OCSF URL from certificate
openssl x509 -in cert.pem -noout -ocsp_uri

# Perform OCSF query
openssl ocsp -issuer issuer_cert.pem \
    -cert cert.pem \
    -url <OCSF_URL> \
    -resp_text

# With CA bundle for verification
openssl ocsp -issuer issuer_cert.pem \
    -cert cert.pem \
    -CAfile ca-bundle.pem \
    -url <OCSF_URL> \
    -resp_text
```

Listing 3: OCSF query using OpenSSL

6.4 OCSF Response Analysis

Key fields in an OCSF response:

- **Response Status:** Indicates if the query was successful
- **Certificate Status:** Good, Revoked, or Unknown
- **This Update:** When the response was generated
- **Next Update:** When the next update will be available
- **Response Signature:** Digital signature of the response
- **Responder ID:** Identity of the OCSF responder

6.5 OCSF Query and Execution

The OCSF query was successfully executed against the responder `http://ocsp01.pec.it/va/arubapec-eidas-g1` using OpenSSL:

```
openssl ocsp -issuer issuer.pem -cert cert_0.pem \  
  -url http://ocsp01.pec.it/va/arubapec-eidas-g1 \  
  -resp_text
```

The query returned a successful response (status 0x0), indicating the OCSF responder is operational and able to provide certificate status information.

6.6 OCSF Response Analysis

The OCSF response (Basic OCSF Response, version 1) was produced at Dec 16 15:06:28 2025 GMT by the ArubaPEC EU Qualified Certificates OCSF Responder G1 (organizationIdentifier=VA01879020517).

Certificate Status: The certificate with serial number 607E88FCE0F3C500:7C11112D902046A5 has a status of **good**, confirming it is valid and not revoked. The certificate identification uses SHA-1 hashing algorithm with the following identifiers:

- Issuer Name Hash: 3BD45E1A2FB99F6E:CBF338A158E63773:CBE3775B
- Issuer Key Hash: C66F3B857BD126B1:789A42A425690CF6:FF7AA067

Update Interval: The OCSF response provides temporal information with This Update at Dec 16 14:48:13 2025 GMT and Next Update at Dec 17 14:48:13 2025 GMT, yielding a 24-hour update interval:

$$\text{OCSF Update Interval} = \text{Next Update} - \text{This Update} = 24 \text{ hours}$$

This synchronization with the CRL update schedule ensures consistency between both revocation checking mechanisms.

Response Extensions: The OCSF response includes several important extensions. The Archive Cutoff date (Apr 26 06:28:06 2017 GMT) indicates that the OCSF responder maintains revocation information for certificates issued after this date. The OCSF Nonce (04109963208:36F44BECC3A708:508E3D6916B) helps prevent replay attacks by ensuring the response is fresh and was generated specifically for this request. The response itself is digitally signed using sha256WithRSAEncryption by the OCSF responder certificate, ensuring its authenticity.

6.7 OCSP vs CRL Comparison

Characteristic	OCSP	CRL
Update Interval	24 hours	24 hours
Response Size	Small (few KB)	Large (2.7 MB)
Real-time Query	Yes	No
Bandwidth Efficiency	High	Low
Certificate Status	good	not listed
Last Update	Dec 16 14:48:13	Dec 16 14:48:13

Table 1: Comparison between OCSP and CRL for the analyzed certificate

Both methods confirm that the certificate is valid and not revoked. OCSP provides a more efficient mechanism for real-time verification, while CRL offers offline verification capability.

7 Results and Findings

7.1 Signature Verification Results

The digital signature verification of `test_signed.pdf` yielded the following results:

Verification Aspect	Result
Signature Validity	Valid
Document Integrity	Verified
Signing Time	Dec 08 2025 15:49:26
Hash Algorithm	SHA-256
Signature Type	ETSI.CAdES.detached
Signed Ranges	[0-11238], [30184-47765]
Total Document Signed	Yes

Table 2: Digital signature verification results

The signature is mathematically valid and covers the entire document, ensuring no part of the PDF has been modified after signing.

7.2 Certificate Analysis Summary

Field	Value
Signer Name	Fabrizio d'Amore
Italian Tax Code	DMRFRZ60P04H501I
Certificate Type	eIDAS Qualified Certificate
Issuing CA	ArubaPEC EU Qualified CA G1
Validity Period	Nov 5 2024 - Nov 5 2027
Key Size	RSA 2048-bit
Key Usage	Non Repudiation (critical)
Signature Algorithm	sha256WithRSAEncryption

Table 3: Certificate summary

7.3 Revocation Status Verification

Both CRL and OCSP verification methods confirm the certificate's validity:

- **CRL Status:** Certificate NOT present in revocation list (valid)
- **OCSP Status:** Certificate status returned as "good"
- **Update Frequency:** Both methods update every 24 hours
- **Last Verified:** Dec 16 2025 14:48:13 GMT

7.4 Security Assessment

7.4.1 Strengths

1. **Strong Cryptography:** Uses SHA-256 hash and RSA-2048, both considered secure
2. **eIDAS Compliance:** Qualified certificate provides legal standing in EU
3. **Non-Repudiation:** Signer cannot deny having signed the document
4. **Complete Document Coverage:** Entire PDF is included in signature
5. **Valid Certificate:** Currently valid and not revoked
6. **Dual Revocation Checking:** Both CRL and OCSP available

7.4.2 Considerations

1. **Root CA Trust:** Verification of trust chain requires ArubaPEC root CA in system trust store
2. **24-hour Update Window:** Newly revoked certificates may not be detected for up to 24 hours
3. **Internet Dependency:** Real-time verification requires active internet connection

7.5 Timeline Analysis

Event	Date/Time
Certificate Issued	Nov 5 2024 13:24:18 GMT
Document Signed	Dec 8 2025 15:49:26 GMT
Analysis Performed	Dec 16 2025 (multiple times)
CRL Last Update	Dec 16 2025 14:48:13 GMT
OCSP Response Generated	Dec 16 2025 15:06:28 GMT
Certificate Expires	Nov 5 2027 13:24:18 GMT

Table 4: Timeline of key events

The certificate was valid at signing time and remains valid at the time of analysis. The signature will remain valid as long as the certificate was valid when the document was signed, even after the certificate expires (thanks to the embedded timestamp).

7.6 Compliance with Verification Checklist

Reviewing against the comprehensive verification checklist defined in Section 2:

Verification Item	Status
<i>Signature Integrity</i>	
Signature mathematically correct	
Document not modified after signing	
Hash validation	
<i>Certificate Validation</i>	
Certificate chain extracted	
Certificate valid at signing time	
Correct key usage extensions	
Valid X.509 format	
<i>Revocation Status</i>	
CRL check performed	
CRL current and valid	
OCSP check performed	
OCSP response valid	
<i>Trust Validation</i>	
Root CA identified	
Certificate policies checked	
<i>Timestamp Verification</i>	
Signing time within validity	
<i>PAdES-Specific</i>	
PAdES compliance verified	
Signature dictionary validated	
ETSI.CAdES.detached format	

Table 5: Verification checklist compliance

All verification checks passed successfully, confirming the digital signature is valid and trustworthy.

8 Conclusion

This homework presented a comprehensive analysis of digital signature verification for PAdES-signed PDF documents, with focus on the practical examination of `test_signed.pdf`.

8.1 Summary of Findings

The analysis successfully accomplished all required objectives:

1. **Verification Checklist:** Developed a comprehensive 20+ point checklist covering signature integrity, certificate validation, revocation status, trust validation, timestamp verification, and PAdES-specific checks.
2. **Certificate Chain Extraction:** Successfully extracted the digital signature and certificate from the PDF using a combination of PyPDF2 for PDF parsing and OpenSSL for PKCS#7 signature processing.
3. **X.509 Field Analysis:** Conducted detailed analysis of all certificate fields including basic information (version, serial number, validity), distinguished names, public key information, and 10+ X.509v3 extensions including key usage, AIA, CRL distribution points, certificate policies, and qualified certificate statements.
4. **CRL Update Interval:** Determined that the CRL is updated every 24 hours (Last Update: Dec 16 14:48:13 2025 GMT, Next Update: Dec 17 14:48:13 2025 GMT), providing a reasonable balance between revocation information freshness and system efficiency.
5. **OCSP Analysis:** Successfully queried the OCSP responder and analyzed the response, confirming certificate status as "good" with the same 24-hour update interval as the CRL, demonstrating synchronized revocation checking mechanisms.

8.2 Key Observations

8.2.1 Technical Excellence

The analyzed signature demonstrates best practices in digital signature implementation:

- Use of strong cryptographic algorithms (SHA-256, RSA-2048)
- Compliance with European eIDAS regulation for qualified certificates
- Complete document coverage in signature
- Proper key usage restrictions (non-repudiation only)
- Dual revocation checking mechanisms (CRL + OCSP)

8.2.2 Legal Standing

As an eIDAS qualified certificate, this signature has legal equivalence to handwritten signatures within the European Union, making it suitable for legally binding documents, contracts, and official communications.

8.2.3 Revocation Architecture

ArubaPEC implements a robust revocation checking architecture with:

- Daily CRL updates (24-hour cycle)
- Real-time OCSP responses
- Synchronized update schedules
- Large CRL size (2.7 MB) indicating active certificate management
- Archive cutoff date preventing infinite CRL growth

8.3 Tools and Methodology

The analysis was conducted using open-source tools and custom Python scripts:

- `pdfsig` (Poppler) for initial signature verification
- `PyPDF2` for PDF structure parsing and signature extraction
- `OpenSSL` for certificate analysis, CRL processing, and OCSP queries
- Custom Python automation for workflow integration

All scripts and analysis results are reproducible and documented in the project repository.

8.4 Final Verdict

SIGNATURE VERIFICATION: **PASSED**

The digital signature on `test_signed.pdf` is **valid**, the document has **not been tampered with**, the certificate is **currently valid and not revoked**, and the signature was created by a **qualified certificate** under eIDAS regulation.

The signature can be trusted for legal and business purposes, subject to verification that the ArubaPEC root CA is trusted by the verifying party.